



ZAP Scanning Report

Site: <http://host.docker.internal:3333>

Generated on Mon, 7 Sept 2026 22:45:01

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	7
Informational	2
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP warnings logged - see the zap.log file for details	1
Info	Informational	http://host.docker.internal:3333	Percentage of responses with status code 2xx	100 %
Info	Informational	http://host.docker.internal:3333	Percentage of endpoints with content type application/javascript	20 %
Info	Informational	http://host.docker.internal:3333	Percentage of endpoints with content type image/svg+xml	20 %
Info	Informational	http://host.docker.internal:3333	Percentage of endpoints with content type text/css	20 %
Info	Informational	http://host.docker.internal:3333	Percentage of endpoints with content type text/html	40 %
Info	Informational	http://host.docker.internal:3333	Percentage of endpoints with method GET	100 %
Info	Informational	http://host.docker.internal:3333	Count of total endpoints	5

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	2
Sub Resource Integrity Attribute Missing	Medium	Systemic
Cross-Origin-Embedder-Policy Header Missing or Invalid	Low	3
Cross-Origin-Opener-Policy Header Missing or Invalid	Low	3
Cross-Origin-Resource-Policy Header Missing or Invalid	Low	5
Permissions Policy Header Not Set	Low	4
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
Timestamp Disclosure - Unix	Low	1
X-Content-Type-Options Header Missing	Low	Systemic
Modern Web Application	Informational	3
Storable and Cacheable Content	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	
Attack	
Evidence	

Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	2
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.

	If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	Sub Resource Integrity Attribute Missing
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Other Info	
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Rubik:wght@300;400;500;600;700&display=swap" rel="stylesheet" />
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml

Method	GET
Parameter	
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	<link href="https://fonts.googleapis.com/css2?family=Rubik:wght@300;400;500;600;700&display=swap" rel="stylesheet" />
Other Info	
Instances	Systemic
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	Cross-Origin-Embedder-Policy Header Missing or Invalid
Description	Cross-Origin-Embedder-Policy header is a response header that prevents a document from loading any cross-origin resources that don't explicitly grant the document permission (using CORP or CORS).
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	

URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	Cross-Origin-Embedder-Policy
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that the application/web server sets the Cross-Origin-Embedder-Policy header appropriately, and that it sets the Cross-Origin-Embedder-Policy header to 'require-corp' for documents. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Embedder-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-embedder-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Opener-Policy Header Missing or Invalid
Description	Cross-Origin-Opener-Policy header is a response header that allows a site to control if others included documents share the same browsing context. Sharing the same browsing context with untrusted documents might lead to data leak.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml

Method	GET
Parameter	Cross-Origin-Opener-Policy
Attack	
Evidence	
Other Info	
Instances	3
Solution	Ensure that the application/web server sets the Cross-Origin-Opener-Policy header appropriately, and that it sets the Cross-Origin-Opener-Policy header to 'same-origin' for documents. 'same-origin-allow-popups' is considered as less secured and should be avoided. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Opener-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-opener-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Opener-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Cross-Origin-Resource-Policy Header Missing or Invalid
Description	Cross-Origin-Resource-Policy header is an opt-in header designed to counter side-channels attacks like Spectre. Resource should be specifically set as shareable amongst different origins.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Node Name	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	Cross-Origin-Resource-Policy

Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/vite.svg
Node Name	http://host.docker.internal:3333/vite.svg
Method	GET
Parameter	Cross-Origin-Resource-Policy
Attack	
Evidence	
Other Info	
Instances	5
Solution	Ensure that the application/web server sets the Cross-Origin-Resource-Policy header appropriately, and that it sets the Cross-Origin-Resource-Policy header to 'same-origin' for all web pages. 'same-site' is considered as less secured and should be avoided. If resources must be shared, set the header to 'cross-origin'. If possible, ensure that the end user uses a standards-compliant and modern web browser that supports the Cross-Origin-Resource-Policy header (https://caniuse.com/mdn-http_headers_cross-origin-resource-policy).
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy
CWE Id	693
WASC Id	14
Plugin Id	90004

Low	Permissions Policy Header Not Set
Description	Permissions Policy Header is an added layer of security that helps to restrict from unauthorized access or usage of browser/client features by web resources. This policy ensures the user privacy by limiting or specifying the features of the browsers can be used by the web resources. Permissions Policy provides a set of standard HTTP headers that allow website owners to limit which features of browsers can be used by the page such as camera, microphone, location, full screen etc.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333

Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/assets/index-BjQUO07R.js
Node Name	http://host.docker.internal:3333/assets/index-BjQUO07R.js
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Permissions-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Permissions-Policy https://developer.chrome.com/blog/feature-policy/ https://scotthelme.co.uk/a-new-security-header-feature-policy/ https://w3c.github.io/webappsec-feature-policy/ https://www.smashingmagazine.com/2018/12/feature-policy/
CWE Id	693
WASC Id	15
Plugin Id	10063

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your

	web/application server is subject to.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	
Attack	
Evidence	nginx/1.31.5
Other Info	
URL	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Node Name	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Method	GET
Parameter	
Attack	
Evidence	nginx/1.31.5
Other Info	
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	
Attack	
Evidence	nginx/1.31.5
Other Info	
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	nginx/1.31.5
Other Info	
URL	http://host.docker.internal:3333/vite.svg
Node Name	http://host.docker.internal:3333/vite.svg
Method	GET
Parameter	
Attack	
Evidence	nginx/1.31.5
Other Info	

Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	Timestamp Disclosure - Unix
------------	------------------------------------

Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://host.docker.internal:3333/assets/index-BjQUO07R.js
Node Name	http://host.docker.internal:3333/assets/index-BjQUO07R.js
Method	GET
Parameter	
Attack	
Evidence	1540483477
Other Info	1540483477, which evaluates to: 2018-10-25 16:04:37.
Instances	1
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-Content-Type-Options Header Missing
------------	--

Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

URL	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Node Name	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:3333/vite.svg
Node Name	http://host.docker.internal:3333/vite.svg
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

	At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-BjQUO07R.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-BjQUO07R.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	<script type="module" crossorigin src="/assets/index-BjQUO07R.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	3

Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Storable and Cacheable Content
Description	The response contents are storable by caching components such as proxy servers, and may be retrieved directly from the cache, rather than from the origin server by the caching servers, in response to similar requests from other users. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where "shared" caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	http://host.docker.internal:3333
Node Name	http://host.docker.internal:3333
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Node Name	http://host.docker.internal:3333/assets/index-BY5Enl6a.css
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:3333/robots.txt
Node Name	http://host.docker.internal:3333/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:3333/sitemap.xml
Node Name	http://host.docker.internal:3333/sitemap.xml

Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
URL	http://host.docker.internal:3333/vite.svg
Node Name	http://host.docker.internal:3333/vite.svg
Method	GET
Parameter	
Attack	
Evidence	
Other Info	In the absence of an explicitly specified caching lifetime directive in the response, a liberal lifetime heuristic of 1 year was assumed. This is permitted by rfc7234.
Instances	Systemic
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.w3.org/Protocols/rfc2616/rfc2616-sec13.html
CWE Id	524
WASC Id	13
Plugin Id	10049

Sequence Details

With the associated active scan results.